بِسْمِ اللّٰهِ الرَّحْمٰنِ الرَّحِيْمِ

اَلْحَمْدُ لِلّٰهِ رَبِّ الْعَالَمِيْنَ

وَالصَّلٰوةُ وَالسَّلَامُ عَلٰى خَاتَمِ النَّبِيِّيْنَ

Computer Security:Principles and Practice

Fourth Edition By: William Stallings and Lawrie Brown

Chapter 6

Malicious Software

Malware

NIST 800-83 defines malware as:

"a **program** that is inserted into a system, **usually covertly**, with the intent of **compromising the confidentiality, integrity, or availability** of the victim's data, applications, or operating system or otherwise annoying or disrupting the victim."

Attack Sources



Advanced Persistent Threats (APTs)

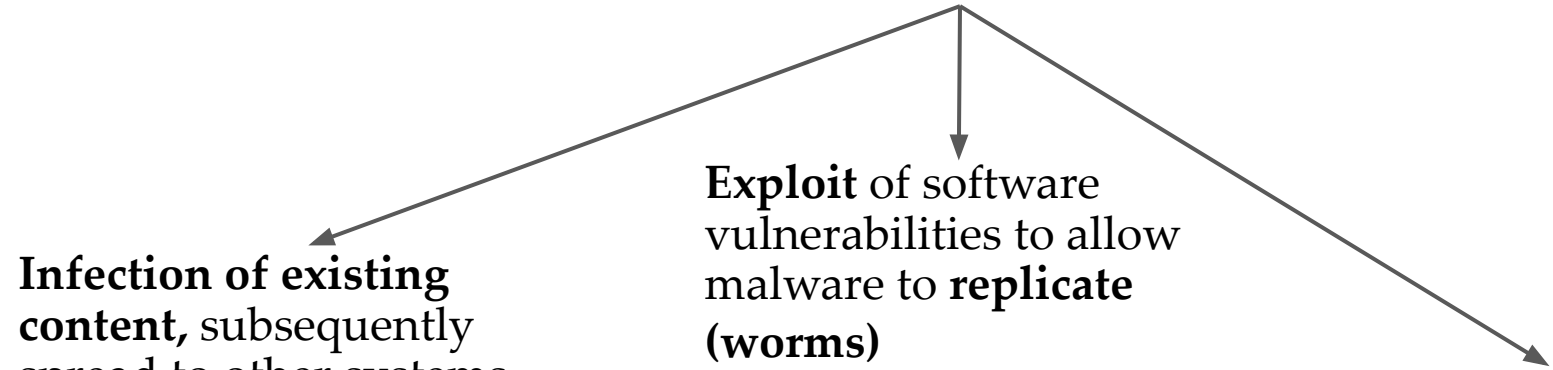
- **Well-resourced, persistent** application of a wide variety of intrusion technologies and malware to selected targets (usually **business or political**)
- Typically attributed to **state-sponsored** organizations and **criminal enterprises**
- Differ from other types of attack by their careful target selection and stealthy intrusion efforts over extended periods
- High profile examples include **Pegasus, Aurora, RSA, APT1, and Stuxnet**

Malware
broadly categorized by:

how it spreads

Its actions (payloads)

Types of Malware (by Propagation)



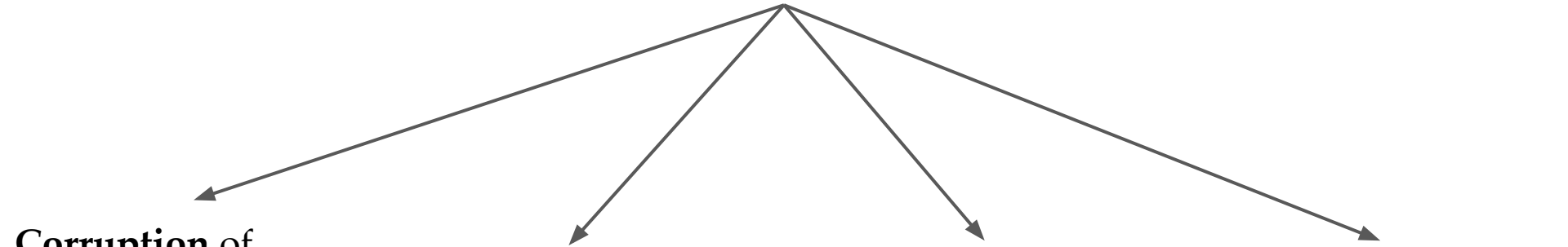
Infection of existing content, subsequently spread to other systems **(viruses)**

Exploit of software vulnerabilities to allow malware to **replicate (worms)**

Social engineering to convince users to: install malware, (**Trojans)** or to open compromised links (**phishing**)

A **blended attack** uses multiple methods of propagation, to maximize the speed and the severity of the attack

Types of Malware (by Action/Payload)



Corruption of system or data files (**Ransomware**)

Theft of **service (**making a **zombie/bot)**

Theft of **information (Spyware** e.g. keylogging**)**

Keeping **Covert Access** to system **(Backdoor, Rootkit)**

Viruses

- Piece of software that infects programs (**injects code**)
  - Modifies them to include a copy of the virus
  - Replicates and goes on to infect other content
  - Easily spread through network environments
- When attached to an executable program a virus can do anything that the program is permitted to do
  - Executes secretly when the host program is run
- Specific to operating system and hardware
  - Takes advantage of their details and weaknesses

Virus Components

Infection mechanism

- Means by which a virus spreads or propagates
- Also referred to as the *infection vector*

Trigger

- Event or condition that determines when the payload is activated or delivered
- Sometimes known as a *logic bomb* (e.g. **data/time** or **count of the number copies made.**

Payload

- What the virus does (besides spreading)
- May involve damage or benign but noticeable activity

Virus Targets

- Boot sector infector

Infects a **boot record** (code to load the OS bootloader) and spreads when a system is booted from the disk containing the virus

- File infector

Infects **files** that the operating system or shell considers to be **executable**

- Macro virus

Infects files with **macro** or scripting code that is interpreted by an application (e.g. for automation in MS-Word or forms in PDF)

Virus Concealment

- **Encrypted virus**

A portion of the virus creates a random encryption key and **encrypts** the remainder of the virus

- **Polymorphic virus**

A virus that **mutates with every infection**.(creates copies that are functionally equivalent but have distinctly different bit patterns) t**o defeat anti viruses looking for "signatures**"

e.g. the virus may randomly insert superfluous instructions or interchange the order of independent

instructions.

- **Metamorphic virus**

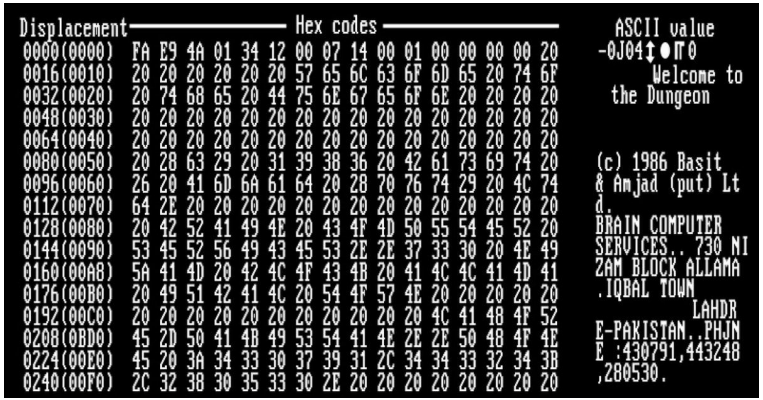
A virus that **mutates and rewrites itself completely** at each iteration and may change behavior as well as appearance (increasing the difficulty of detection)

The Brain virus

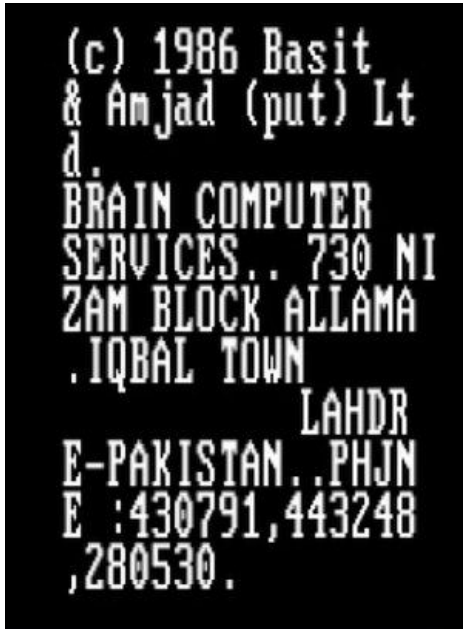
Arguable the first effective virus written by: **Basit and Amjad Farooq Alvi (Lahore)**

Boot sector virus targeting MS-DOS systems: Replaced the boot sector of floppy disks; spread through infected disks.

Initially intended as a copy-protection tool



Displacement	Hex codes															ASCII value
0000(0000)	FA	E9	4A	01	34	12	00	07	14	00	01	00	00	00	00	20	-0J04‡●Π0
0016(0010)	20	20	20	20	20	20	57	65	6C	63	6F	6D	65	20	74	6F	Welcome to
0032(0020)	20	74	68	65	20	44	75	6E	67	65	6F	6E	20	20	20	20	the Dungeon
0048(0030)	20	20	20	20	20	20	20	20	20	20	20	20	20	20	20	20	
0064(0040)	20	20	20	20	20	20	20	20	20	20	20	20	20	20	20	20	
0080(0050)	20	28	63	29	20	31	39	38	36	20	42	61	73	69	74	20	(c) 1986 Basit
0096(0060)	26	20	41	6D	6A	61	64	20	28	70	76	74	29	20	4C	74	& Amjad (put) Lt
0112(0070)	64	2E	20	20	20	20	20	20	20	20	20	20	20	20	20	20	d.
0128(0080)	20	42	52	41	49	4E	20	43	4F	4D	50	55	54	45	52	20	BRAIN COMPUTER
0144(0090)	53	45	52	56	49	43	45	53	2E	2E	37	33	30	20	4E	49	SERVICES.. 730 NI
0160(00A8)	5A	41	4D	20	42	4C	4F	43	4B	20	41	4C	4C	41	4D	41	ZAM BLOCK ALLAMA
0176(00B0)	20	49	51	42	41	4C	20	54	4F	57	4E	20	20	20	20	20	.IQBAL TOWN
0192(00C0)	20	20	20	20	20	20	20	20	20	20	20	4C	41	48	4F	52	LAHDR
0208(0BD0)	45	2D	50	41	4B	49	53	54	41	4E	2E	2E	50	48	4F	4E	E-PAKISTAN..PHJN
0224(00E0)	45	20	3A	34	33	30	37	39	31	2C	34	34	33	32	34	3B	E :430791,443248
0240(00F0)	2C	32	38	30	35	33	30	2E	20	20	20	20	20	20	20	20	,280530.



Brain Virus (1986)

Boot sector virus

- Spread via infected floppy disks.
- When a floppy was inserted and booted, the virus copied itself to the Master Boot Record (MBR) of the hard drive.
- Any floppy created on that system then became a carrier.

Replaced the boot sector code of floppy disks with its own loader. When the PC booted from an infected disk, the virus hooked into DOS interrupt routines (INT 13h) to intercept disk access and replicate onto new floppies.

Targeted MSDOS PCs

Chernobyl Virus (1998)

File infector virus

Named for April 26th activation i.e. anniversary of the 1986 Chernobyl nuclear disaster

- Spread through infected executable (`.exe`) files (bundled with pirated software).
- Once executed, it stayed resident in memory and infected other `.exe` files.
- On trigger dates, it overwrote critical parts of the hard drive and sometimes the system BIOS.

Infected portable executable (PE) files by inserting malicious code into gaps in the file structure without changing file size. On trigger date, it overwrote the first megabyte of the system drive and flashed the BIOS, rendering machines unbootable.

Targeted Windows 95/98 systems.

Worms

- Program that actively seeks out more machines to infect and each infected machine serves as an automated launching pad for attacks on other machines
- **Exploits software vulnerabilities in client or server programs (to be discussed)**
- Can use network connections to spread from system to system
- Spreads through shared media (USB drives, CD, DVD data disks)
- E-mail worms spread in macro or script code included in attachments and instant messenger file transfers
- Upon activation the worm may replicate and propagate again
- Usually carries some form of payload
- First known implementation was done in Xerox Palo Alto Labs in the early 1980s

Worm Replication

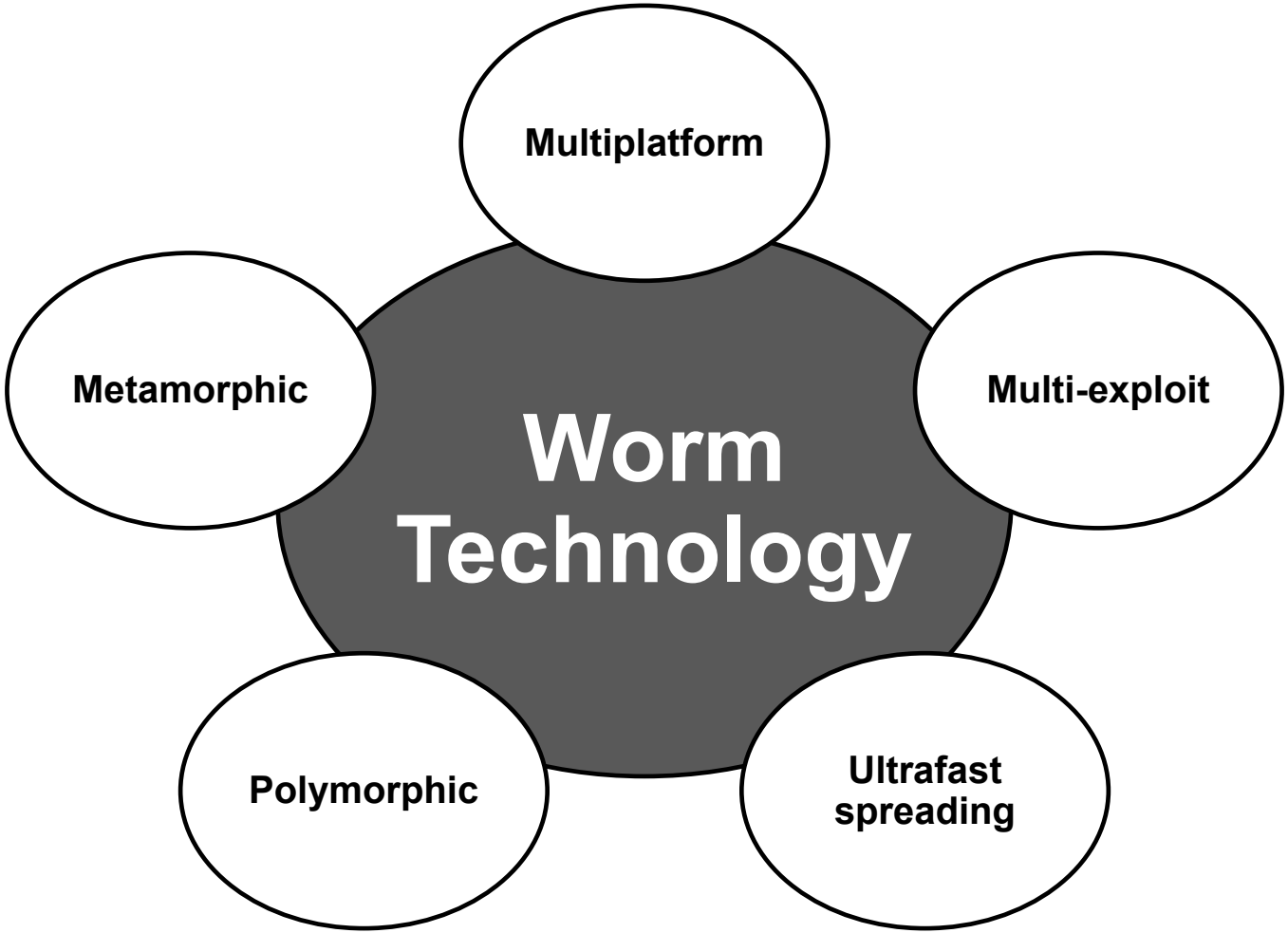
Email	• Worm e-mails a copy of itself to other systems • Sends itself as an attachment via an instant message service
File sharing	• Creates a copy of itself or infects a file as a virus on removable media
Remote file execution	• Worm executes a copy of itself on another system
Remote file access	• Worm uses a remote file access or transfer service to copy itself from one system to the other
Remote login	• Worm logs onto a remote system as a user and then uses commands to copy itself from one system to the other

Target Discovery

Scanning (or fingerprinting)

First function in the propagation phase for a network worm: Searches for other systems to infect by:

- **Random**
  - Each compromised host probes random addresses in the IP address space using a different seed
  - This produces a high volume of Internet traffic which may cause generalized disruption even before the actual attack is launched
- **Hit-list**
  - The attacker first compiles a long list of potential vulnerable machines
  - Once the list is compiled the attacker begins infecting machines on the list
  - Each infected machine is provided with a portion of the list to scan
  - This results in a very short scanning period which may make it difficult to detect that infection is taking place
- **Topological**
  - This method uses information contained on an infected victim machine to find more hosts to scan
- **Local subnet**
  - If a host can be infected behind a firewall that host then looks for targets in its own local network
  - The host uses the subnet address structure to find other hosts that would otherwise be protected by the firewall


Multiplatform
Metamorphic
Worm Technology
Multi-exploit
Polymorphic
Ultrafast spreading

Morris Worm



https://blog.thinkreliability.com/case-study-the-morris-worm-brings-down-the-internet

- **Earliest significant worm infection**
- Released by Robert Morris in 1988
- Designed to spread on UNIX systems
  - Attempted to crack local password file to use login/password to logon to other systems
  - Exploited a bug in the finger protocol which reports the whereabouts of a remote user
  - Exploited a trapdoor in the debug option of the remote process that receives and sends mail
- Successful attacks achieved communication with the operating system command interpreter
  - Sent interpreter a bootstrap program to copy worm over

Morris Worm (1988)

Internet worm (first major worm: **Brought down the internet**)

Exploited multiple vulnerabilities:

- Weak/default passwords via remote login (*via dictionary attack*)
- A buffer overflow in the `finger` daemon. *Allowing worm to run shell code*
- A bug in `sendmail` *that allowed remote command execution.*

Spread across Unix systems connected to ARPANET.

The `finger` daemon (`fingerd`) was a Unix service that let users query information about other users on the system (e.g., login status).

Sendmail was Unix mail transfer agent. Its bug being: its debug mode allowed remote users to issue SMTP commands that executed shell commands

Moris worm exploited both

WannaCry

Ransomware attack in May 2017 that spread extremely fast over a period of hours to days, infecting hundreds of thousands of systems belonging to both public and private organizations in more than 150 countries

It spread as a worm by aggressively scanning both local and random remote networks, attempting to exploit a vulnerability in the SMB file sharing service on unpatched Windows systems

This rapid spread was only slowed by the accidental activation of a “kill-switch” domain by a UK security researcher

Once installed on infected systems, it also encrypted files, demanding a ransom payment to recover them

WannaCry Worm (2017)

Ransomware worm

- Exploited the SMB protocol vulnerability EternalBlue in Windows.
- Once inside, it self propagated across networks without user interaction.
- Encrypted files and demanded ransom in Bitcoin.

Targeted Unpatched Windows systems worldwide.

WannaCry spread by scanning for systems with SMBv1 open on port 445, exploiting them with EternalBlue to run shellcode

SMB (Server Message Block) is the Windows protocol for file sharing. Its version, SMBv1, contained a serious vulnerability termed EternalBlue, that allowed attackers to send crafted SMB packets that triggered a buffer overflow, enabling remote shell code execution with system privileges.

Social Engineering

"Tricking" users to assist in the compromise of their own systems

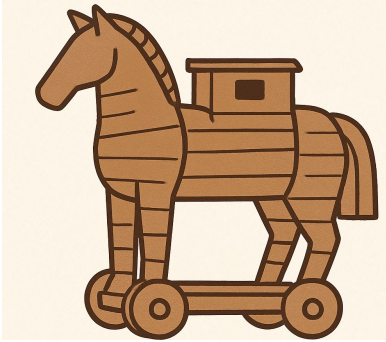
Spam

- Unsolicited bulk e-mail
- Significant carrier of malware
- Used for phishing attacks

Trojan horse

- Program or utility containing harmful hidden code
- Used to accomplish functions that the attacker could not accomplish directly

Trojans



A useful, or apparently useful, program or utility containing hidden code that, when invoked, performs some unwanted or harmful function.

Example:
To gain access to sensitive information (e.g. banking credentials) on system a Trojan horse can “claim” to be the latest anti-virus scanner, or security update.

Hence, users need to take precautions to validate the source of any software they install.

Tech Support Scams are a growing social engineering concern. i.e. centers calling users about nonexistent problems on their computer systems then the attackers try to sell them bogus tech support or ask them to install Trojan malware or other unwanted applications on their systems,

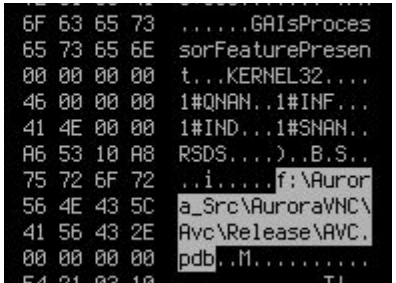
Hydraq Trojan (Operation Aurora,2009)

Remote Access Trojan (RAT)

- Spread through targeted phishing emails.
- Contained malicious attachments exploiting Internet Explorer vulnerabilities.
- Once installed, it gave attackers backdoor access **to steal intellectual property.**

Target: Large corporations (e.g., Google, Adobe).

Vulnerability in Internet Explorer: When opening a malicious webpage or file it could corrupt memory and let attackers run any program with the user's access rights.



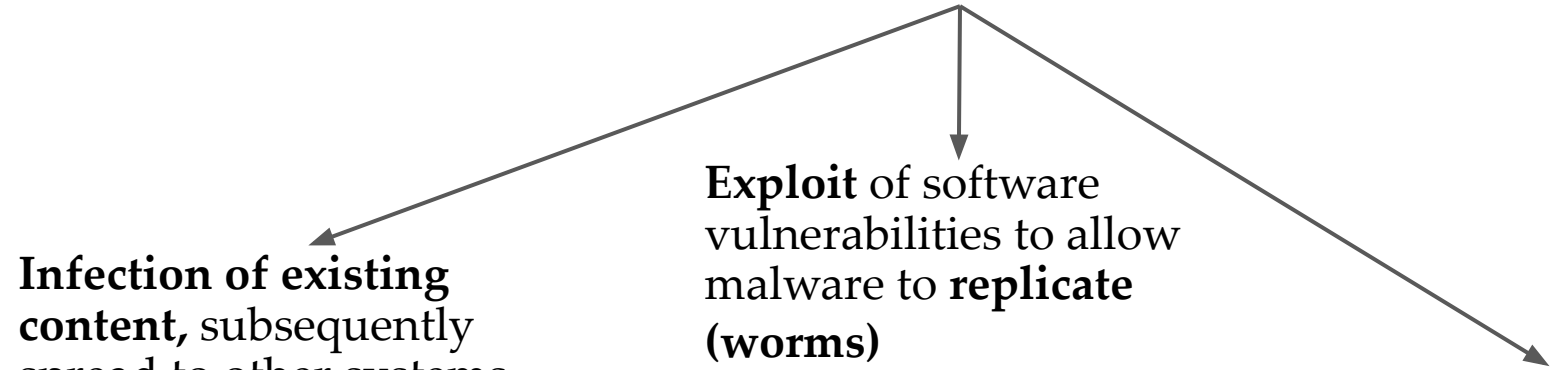
Zeus Trojan (2007)

Banking Trojan

- Spread via phishing emails and upon click malicious downloads (drive-by exploits)
- Once installed, it injected malicious DLLs into browser processes like Internet Explorer.
- This enabled Man in The Browser (MitB) attacks, where Zeus silently captured **logins, credentials, and even altered banking transactions** while appearing normal to the user.

Target: Online banking users and financial institutions.

Types of Malware (by Propagation)



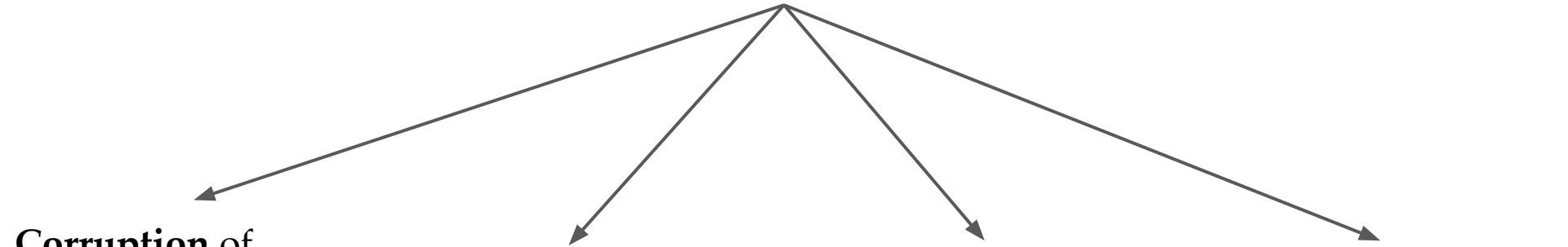
Infection of existing content, subsequently spread to other systems **(viruses)**

Exploit of software vulnerabilities to allow malware to **replicate (worms)**

Social engineering to convince users to: install malware, (**Trojans)** or to open compromised links (**phishing**)

A **blended malware** uses multiple methods of propagation, to maximize the speed and the severity of the attack

Types of Malware (by Action/Payload)



Corruption of system or data files (**Ransomware**)

Theft of **service (**making a **zombie/bot)**

Theft of **information (Spyware** e.g. keylogging**)**

Keeping **Covert Access** to system **(Backdoor, Rootkit)**

Payload
System Corruption

Real-world damage: Causes damage to physical equipment e.g.

- Chernobyl virus: rewrites BIOS code
- Stuxnet worm targets specific industrial control system software
- Ransomware (e.g. wanacry) encrypts the user's data and demands payment in order to access the key needed to recover the information
- Logic bomb: Code embedded in the malware that is set to "explode" when certain conditions are met

Payload – Service Theft (Attack Agents)
Bots

- Takes over another Internet attached computer and uses that computer to launch or manage attacks
- *Botnet* - collection of bots capable of acting in a coordinated manner
- Uses:
  - Distributed denial-of-service (DDoS) attacks
  - Spamming
  - Sniffing traffic
  - Keylogging
  - Spreading new malware
  - Installing advertisement add-ons and browser helper objects (BHOs)
  - Attacking IRC chat networks
  - Manipulating online polls/games

Payload – Information Theft

Keylogger

- Captures keystrokes to allow attacker to monitor sensitive information
- Typically uses some form of filtering mechanism that only returns information close to keywords (“login”, “password”)

Spyware

- Subverts the compromised machine to allow monitoring of a wide range of activity on the system
  - Monitoring history and content of browsing activity
  - Redirecting certain Web page requests to fake sites
  - Dynamically modifying data exchanged between the browser and certain Web sites of interest

Phishing

- Exploits social engineering to leverage the user’s trust by masquerading as communication from a trusted source

Payload – Stealthing

Backdoor:

- Also known as a *trapdoor*
- Secret entry point into a program allowing the attacker to gain access and bypass the security access procedures
- *Maintenance hook* is a backdoor used by Programmers to debug and test programs
- Difficult to implement operating system controls for backdoors in applications

Rootkit:

Hidden set of programs that grants attackers covert administrator-level access, subverts system monitoring, and enables them to alter files, control processes, and maintain backdoor access.

Attack Kits

- Initially the development and deployment of malware required considerable technical skill by software authors
  - The development of virus-creation toolkits in the early 1990s and then more general attack kits in the 2000s greatly assisted in the development and deployment of malware
- Toolkits are often known as “crimeware”
  - Include a variety of propagation mechanisms and payload modules that even novices can deploy
  - Variants that can be generated by attackers using these toolkits creates a significant problem for those defending systems against them
- Examples are:
  - Zeus
  - Angler

Malware Countermeasure Approaches

- Ideal solution to the threat of malware is **prevention**

Four main elements of prevention:

- Policy
- Awareness
- Vulnerability mitigation
- Threat mitigation

- If prevention fails, **technical mechanisms** can be used to support the following threat mitigation options:
  - Detection
  - Identification
  - Removal

Generations of Anti-Virus Software

First generation: simple scanners

- Requires a malware signature to identify the malware
- Limited to the detection of known malware i.e. reported in a collaborative database

Second generation: heuristic scanners

- Uses heuristic rules to search for probable malware instances (within the code e.g. encryption or instruction for modifying other files)
- Another approach is integrity checking (keeping track of and verifying hash for files)

Third generation: activity traps

- Memory-resident programs that identify malware by its actions rather than its structure in an infected program (e.g. a program replicating itself, mass mailing or keylogging)

Fourth generation: full-featured protection

- Packages consisting of a variety of anti-virus techniques used in conjunction
- Include scanning and activity trap components and access control capability

Sandbox Analysis

- Running potentially malicious code in an emulated sandbox or on a virtual machine
- Allows the code to execute in a controlled environment where its behavior can be closely monitored without threatening the security of a real system
- Running potentially malicious software in such environments enables the detection of complex encrypted, polymorphic, or metamorphic malware
- The most difficult design issue with sandbox analysis is to determine how long to run each interpretation

Summary

- Types of malicious software (malware)
  - Broad classification of malware
  - Attack kits
  - Attack sources (APTs)
- Propagation-Virus
  - Virus components
  - Virus Targets
  - Concealment
- Propagation-vulnerability exploit-worms
  - Target discovery
  - Brief history of worm attacks
- Propagation-social engineering-spam E-mail, Trojans
- Payload-system corruption
- Payload-attack agent-zombie, bots
- Payload-information theft-keyloggers, phishing, spyware
- Payload-stealthing-backdoors, rootkits
- Malware Countermeasures